

Insurance Claims Portal Compromise TTX

Cyber Tabletop Exercise | Facilitation-Ready PDF

Scenario focus: Compromised third-party adjuster account used to access and export claims records containing personal and financial information.

- Primary organization: Property and Casualty Insurance Carrier
- Third party in scope: Third-Party Claims Adjuster
- Audience: Executive crisis leadership, legal/privacy, vendor management, fraud, claims operations, SOC/IR, communications
- Recommended duration: 90 minutes plus 20-minute debrief
- Exercise date reference: Day 1 / Day 2 timeline to adapt to local business hours

1. Exercise Overview

This tabletop exercise is derived from the uploaded STIX 2.1 bundle describing an incident named **Insurance Claims Portal Compromise TTX**. The bundle identifies a property and casualty insurance carrier, a third-party claims adjuster, and four scenario injects: claims export alert, fraudulent claim updates, privacy impact assessment, and vendor access governance review.

The exercise is designed to test how business, security, legal, privacy, vendor management, and communications teams coordinate when a third-party account appears to have been compromised and used to access sensitive claimant information.

Assumptions made to complete the exercise

- The claims portal is a cloud-hosted application used by internal claims teams and approved third-party adjusters.
- The compromised account belongs to the third-party adjuster and has legitimate portal access, but its activity deviates from normal usage patterns.
- The portal contains claimant personal information, claim history, policy information, supporting documents, and payment destination details.
- The exercise does not assume ransomware or destructive activity; the primary concerns are unauthorized access, data exposure, claim fraud, and third-party governance.
- Jurisdictional notification thresholds must be assessed by privacy/legal counsel based on affected claimant residency and applicable insurance/privacy rules.

2. Scope and Participation

In scope	Out of scope
Claims portal monitoring and response Third-party account containment Fraudulent claim modification triage Privacy and breach assessment Vendor notification, governance, and contractual obligations Executive escalation and communications	Live technical testing Real claimant or production data access Attribution to a named threat actor Law-enforcement notification unless exercise participants determine it is needed Public notification drafting beyond high-level holding statements

Recommended participants

- Executive sponsor / crisis chair
- Claims operations lead and fraud operations lead
- SOC lead, incident commander, identity and access management representative
- Privacy counsel / legal counsel / regulatory affairs
- Vendor management / third-party risk management
- Customer communications, media relations, contact center lead
- Business continuity and enterprise risk representatives

3. Objectives

- Validate detection, triage, and escalation pathways for suspicious third-party account activity.
- Assess decision-making for containment of a vendor account without unnecessarily disrupting legitimate claims operations.
- Test coordination between claims, fraud, security, privacy, legal, and vendor management functions.

- Evaluate the organization's ability to determine whether claimant personal and financial information was exposed.
- Clarify ownership of claimant notification, regulatory reporting, vendor contractual notification, and customer-facing communications.
- Identify improvements to third-party access lifecycle controls, MFA enforcement, least privilege, logging, and anomaly detection.

4. Rules of Engagement

- This is a no-fault learning exercise. The goal is to identify process gaps and decision points, not individual performance issues.
- Participants should respond as they would during a real incident, using current roles, responsibilities, policies, and escalation channels.
- Do not fight the scenario. Ask clarifying questions, but make decisions based on incomplete information.
- Real incidents take priority. Participants who need to leave should notify the facilitator.
- All scenario details are fictional and intended for exercise use only.

5. Scenario Narrative

On a normal business day, security monitoring flags unusual bulk export activity from the claims portal. The activity originates from an account assigned to an approved third-party claims adjuster. The account has valid credentials and appears to have passed normal authentication controls, but the volume, time of day, and claim categories accessed are abnormal for the user's historical activity.

Within hours, the fraud team identifies suspicious updates to open claims, including altered payment destination details. The organization must determine whether the activity is a compromised account, an insider issue at the adjuster, a process error, or coordinated fraud. As the investigation progresses, privacy counsel must assess whether personal and financial information was exposed, while vendor management reviews account lifecycle controls, MFA enforcement, and contractual notification obligations.

Key operational tensions

- Containing the adjuster account may interrupt legitimate claims processing and customer service.
- Fraudulent payment changes may require rapid payment holds, claim review, and possible customer outreach.
- Privacy assessment depends on incomplete logs, export contents, claimant residency, and vendor cooperation.
- Vendor management must balance collaboration with formal contractual rights, auditability, and notification obligations.
- Executives need clear thresholds for crisis activation, regulator engagement, and public communications.

6. Exercise Timeline and Injects

Phase	Time	Inject	Core decision	Expected actions
1. Detection and triage	Day 1, 09:00	Security monitoring detects unusual bulk exports of claims records from a third-party adjuster account.	Is this suspicious activity, confirmed compromise, or permitted vendor activity?	Open incident ticket; preserve logs; validate account owner and vendor relationship; compare activity to baseline; identify affected claim records; determine initial severity; brief claims, SOC, fraud, privacy, and vendor management.
2. Fraud signal and containment	Day 1, 11:30	The fraud team identifies suspicious claim updates and altered payment destination details.	Should the organization suspend access, hold payments, and activate crisis coordination?	Disable or restrict the account; force credential reset and MFA review; place holds on suspicious payments; review recent claim changes; establish incident commander; notify vendor contact; initiate evidence preservation.
3. Privacy and regulatory assessment	Day 1, 15:00	Privacy counsel assesses whether claimant personal and financial information was exposed.	Is there a reportable privacy incident or breach?	Confirm data elements exported; assess claimant residency and sensitivity; document decision rationale; prepare notification decision tree; align legal, privacy, claims, and communications; define claimant support options.
4. Vendor governance and recovery	Day 2, 10:00	Vendor management reviews third-party account lifecycle controls, MFA enforcement, and contractual notification obligations.	What controls must be verified before restoring normal vendor access?	Review contract clauses and notification obligations; assess MFA and account lifecycle controls; require vendor attestation; define reactivation criteria; plan post-incident report; assign remediation owners.

Inject 1: 1. Detection and triage

Exercise time: Day 1, 09:00

Inject statement: Security monitoring detects unusual bulk exports of claims records from a third-party adjuster account.

Information available to participants

- The export volume is materially above baseline for this adjuster account.
- Access originated from a device/location pattern not previously associated with the adjuster.
- No customer complaint or fraud loss is confirmed yet.
- Initial logs show multiple claim record exports within a short period.

Discussion questions

- Who owns initial triage and severity classification?
- What evidence is needed before escalating to the crisis team?
- Which logs, exports, and portal audit trails must be preserved?
- What immediate information should be requested from the third-party adjuster?

Expected participant actions

- Assign incident commander and business lead.
- Validate whether the account activity aligns with approved vendor work.
- Preserve logs and exports; prevent overwriting of portal audit data.
- Define initial severity and escalation path.

Facilitator notes

Listen for confusion between SOC technical triage, business impact assessment, and crisis activation. Push participants to identify who can obtain vendor facts quickly and who can preserve evidence.

Inject 2: 2. Fraud signal and containment

Exercise time: Day 1, 11:30

Inject statement: The fraud team identifies suspicious claim updates and altered payment destination details.

Information available to participants

- Fraud team has identified claim records with recent changes to payment destination details.
- Some claims are scheduled for payment later today.
- The adjuster's business contact cannot immediately confirm the activity as legitimate.
- SOC has not yet determined whether credentials, session token, or vendor endpoint was compromised.

Discussion questions

- Who can authorize suspension of the vendor account or the full vendor tenant?
- What criteria trigger payment holds or manual review of claims?
- How will claims operations communicate with affected business teams without creating panic?
- When should legal, privacy, and communications be formally engaged?

Expected participant actions

- Restrict suspicious account access; require reset and session revocation.
- Hold or review impacted claim payments and reverse unauthorized changes where possible.
- Coordinate fraud investigation with SOC and claims operations.
- Create a single source of truth for status, decisions, and action owners.

Facilitator notes

Challenge participants on payment holds and claim backlog. Ask how they avoid over-containment while protecting claimants from fraud.

Inject 3: 3. Privacy and regulatory assessment

Exercise time: Day 1, 15:00

Inject statement: Privacy counsel assesses whether claimant personal and financial information was exposed.

Information available to participants

- Exported records may include names, addresses, policy numbers, claim descriptions, supporting documents, banking/payment data, and adjuster notes.
- There is uncertainty over whether the exported data left the organization's controlled environment or was accessed only within the portal.
- The number of potentially affected claimants remains under investigation.
- Legal and privacy teams need a defensible incident classification and notification plan.

Discussion questions

- What data elements determine whether this is reportable?
- How will the team identify affected claimant populations and jurisdictions?
- What regulatory, customer, or insurer obligations may be triggered?
- What language can be used internally before breach status is confirmed?

Expected participant actions

- Build a data exposure matrix: data types, individuals, jurisdictions, access evidence, export evidence.
- Document breach assessment rationale and notification thresholds.
- Prepare claimant support options such as call center scripts or monitoring decision points if required.
- Control internal and external messaging.

Facilitator notes

Do not let the group jump directly to public breach notification without evidence. Steer them toward a documented legal/privacy assessment and defensible decision record.

Inject 4: 4. Vendor governance and recovery

Exercise time: Day 2, 10:00

Inject statement: Vendor management reviews third-party account lifecycle controls, MFA enforcement, and contractual notification obligations.

Information available to participants

- Vendor management confirms the adjuster has several active users and varying privilege levels.
- MFA enforcement status is not uniformly documented for all vendor users.
- Contractual security and notification clauses need review.
- Business wants to restore vendor access quickly to avoid claims backlog.

Discussion questions

- What evidence must the vendor provide before access is restored?
- What contractual remedies, audit rights, or attestations should be invoked?
- Which access governance controls failed or need improvement?
- What should be included in the post-incident report and lessons learned?

Expected participant actions

- Require vendor root cause statement and control attestation.
- Review all third-party accounts for least privilege, inactive accounts, MFA, shared accounts, and privileged roles.
- Define access restoration criteria and enhanced monitoring period.
- Capture lessons learned, remediation plan, owners, and deadlines.

Facilitator notes

Drive toward concrete governance improvements: access recertification, vendor MFA proof, contractual breach notification SLAs, audit logs, and periodic testing.

7. Decision Points and Escalation Triggers

Decision point	Trigger examples	Decision owner	Outputs
Incident severity	Bulk export; valid third-party account; sensitive data; suspected fraud	Incident commander with SOC and business lead	Severity level, escalation notices, incident bridge
Access containment	Unexplained activity, account compromise suspicion, payment manipulation	SOC/IAM with vendor management and claims operations	Account suspension, session revocation, MFA reset, privileged access review
Payment controls	Altered destination details, pending disbursements, claimant complaints	Fraud operations and claims leadership	Payment holds, manual verification, reversal workflow
Privacy classification	Personal/financial info exposed or exported; unknown recipient; affected jurisdictions	Privacy/legal counsel	Breach assessment memo, notification decision, regulator plan
Crisis activation	Material business, legal, regulatory, reputational, or claimant impact	Executive crisis chair	Crisis cadence, executive briefings, communications strategy
Vendor enforcement	Vendor delay, incomplete evidence, control failures, contractual breach	Vendor management/legal	Formal notice, remediation plan, audit request, access restoration criteria

8. Technical and Business Impacts

Technical impacts

- Potential abuse of a valid third-party account.
- Possible unauthorized bulk export of claims records.
- Untrusted claim record modifications requiring audit and rollback.
- Need for log preservation across portal, identity provider, API, SIEM, and vendor systems.
- Potential gaps in MFA enforcement, session management, and anomaly detection.

Business impacts

- Claims processing delays due to vendor account restrictions and manual claim validation.
- Potential fraudulent payments or payment redirection attempts.
- Claimant trust and reputational impact if sensitive information was exposed.
- Regulatory and contractual reporting obligations across privacy, insurance, and vendor management domains.
- Operational burden on contact center, claims, fraud, legal, and communications teams.

9. Communications Guidance

Internal holding statement

"We are investigating unusual activity involving a third-party claims adjuster account in the claims portal. The investigation is active. Teams are preserving evidence, reviewing potentially affected claim records, and coordinating with the adjuster. Please do not speculate externally or contact claimants unless directed by Legal, Privacy, Communications, or Claims leadership."

External holding statement, if needed

"We are aware of activity involving a third-party account used for claims processing and are actively investigating. We have taken precautionary steps to protect claim records and payment integrity. We will provide additional information to affected

individuals or regulators as appropriate.”

Communication principles

- Use confirmed facts only; avoid saying “breach” until privacy/legal has made that determination.
- Keep a decision log of who approved communications and based on what facts.
- Coordinate customer, regulator, vendor, and media messaging through a single communications lead.
- Prepare call center guidance for claimants whose claims may be delayed due to verification steps.

10. Facilitator Run Sheet

Segment	Duration	Facilitator action
Welcome, objectives, rules	10 min	Set expectations, remind participants to use current processes and roles.
Inject 1	15 min	Read inject; ask triage, evidence, severity, and escalation questions.
Inject 2	20 min	Introduce fraud and payment manipulation; force decisions on containment and business impact.
Inject 3	20 min	Shift focus to privacy, legal, and regulatory decision-making.
Inject 4	15 min	Drive vendor governance, restoration, and remediation decisions.
Debrief	20 min	Capture strengths, gaps, remediation owners, target dates, and policy/playbook updates.

11. Debrief and Lessons Learned Capture

- What worked well in detection, escalation, containment, and business coordination?
- Where were roles or decision rights unclear?
- Was vendor evidence sufficient and timely?
- Could the team identify affected claimants and data elements quickly?
- Were fraud, legal/privacy, claims, and communications synchronized?
- What controls, contracts, playbooks, monitoring rules, or training should change?
- Who owns each remediation item and by what date?

12. Observation Scorecard

Observation	1 Not confident	2 Slightly	3 Some what	4 Fairly	5 Completely	Notes / owner
We can detect abnormal third-party account exports quickly.						
We can preserve claims portal evidence and audit logs.						
We can suspend vendor access without unacceptable business disruption.						
We can identify fraudulent claim updates and payment redirection attempts.						
We can assess privacy impact and notification obligations defensibly.						
We understand vendor contractual notification and control obligations.						
We have clear executive, regulator, claimant, and media communications pathways.						

13. MITRE ATT&CK; Mapping

The STIX bundle does not include explicit ATT&CK; technique objects, so the mapping below reflects the behaviors represented by the scenario and should be validated against the organization's final investigation findings.

Tactic	Technique	Scenario relevance	Detection / validation
Initial Access / Defense Evasion	T1078 – Valid Accounts	A legitimate third-party adjuster account is used to access the claims portal.	Identity provider logs, impossible travel, device fingerprint, unusual user-agent, historical baseline.
Initial Access / Persistence	T1078.004 – Valid Accounts: Cloud Accounts	The claims portal is assumed to be SaaS/cloud-hosted and accessed through an approved vendor identity.	Cloud application audit logs, conditional access, MFA status, session token review.
Collection	T1119 – Automated Collection	Bulk export of claims records suggests scripted or automated collection behavior.	Export volume, API calls, repeated queries, bulk download telemetry.
Collection	T1213 – Data from Information Repositories	Claims portal records and supporting documents are used as a repository of sensitive claimant data.	Portal object access logs, repository export history, document access events.
Exfiltration	T1567 – Exfiltration Over Web Service	If exported data was transferred through portal or cloud/web services, the behavior aligns with web-service-based exfiltration.	Outbound traffic, API export destination, cloud storage indicators, download source/destination logs.
Impact / Fraud enablement	No direct ATT&CK; enterprise technique mapped	Fraudulent claim updates and payment redirection are business-process abuse enabled by account compromise.	Claim audit trails, payment-change workflow logs, dual-control evidence, payment hold decisions.
Defense Evasion / Persistence	T1098 – Account Manipulation	Relevant if the actor changed account settings, MFA methods, permissions, or recovery details to retain access.	IAM change logs, MFA device enrollment, role changes, vendor admin actions.

ATT&CK; source note: MITRE ATT&CK; is a public knowledge base of adversary tactics and techniques. Current official technique references consulted for this mapping include T1078 Valid Accounts, T1119 Automated Collection, T1567 Exfiltration Over Web Service, and T1098 Account Manipulation.

14. Glossary

Term	Meaning
Claims portal	Application used to manage claim records, documents, payment updates, and adjuster workflows.
Third-party adjuster	External organization authorized to handle claims activities on behalf of the carrier.
MFA	Multi-factor authentication.
SOC	Security Operations Center.
SIEM	Security Information and Event Management platform.
IAM	Identity and Access Management.
Breach assessment	Legal/privacy analysis to determine whether an incident triggers notification duties.
Payment redirection	Unauthorized change to destination account or payment instructions.
Evidence preservation	Steps to retain logs, records, images, exports, and decision artifacts for investigation.